Note de pré-projet — FasoMsg

Sprint technique pré-hackathon · Hackathon 226 – Édition 2026 · Challenge : « La messagerie souveraine de l'administration » — Équipe : [Nom de l'équipe] · Université : [Université] · [Membre 1], [Membre 2], [Membre 3]

1. Concept. Les agents publics échangent des informations de service sur des messageries grand public dont les serveurs et les règles échappent à l'État. **FasoMsg** est une messagerie instantanée souveraine qui réconcilie les usages attendus — conversations directes, groupes, fichiers, annuaire officiel — avec les exigences de sécurité administrative. Trois principes la structurent : (1) le serveur est un **relais aveugle** : il ne peut lire ni message ni fichier ; (2) l'identité est **vérifiée à l'entrée** : enrôlement nominatif par code à usage unique, mot de passe scrypt et second facteur TOTP ; (3) la **révocation est immédiate** : un agent révoqué perd l'accès, ses données locales et l'accès aux clés de salons à venir. L'État héberge, contrôle et audite ; le contenu reste aux seuls agents.

2. Architecture. Client web (JavaScript natif) ↔ serveur Node.js (Express + WebSocket) ↔ SQLite (module standard node:sqlite). Un seul conteneur Docker ; « docker compose up » suffit. **Le navigateur** détient toutes les clés privées Olm/Megolm, scellées dans le stockage local par une clé dérivée du mot de passe (PBKDF2-SHA256, 210 000 itérations) ; il chiffre messages et fichiers (AES-GCM 256) avant tout envoi. **Le serveur** gère comptes et rôles (admin / superviseur / agent), sessions (cookies HttpOnly), clés publiques d'appareils, clés jetables, relais d'enveloppes chiffrées (« to-device »), salons, annuaire, journal d'audit et TTL d'expiration. La **WebSocket** pousse les notifications ; le rattrapage passe par HTTP : un appareil revenant en ligne récupère sa file de clés et l'historique — le fonctionnement dégradé en faible connexion est donc natif.

3. Protocole de chiffrement retenu : Matrix Olm/Megolm. Nous retenons la pile cryptographique du **protocole Matrix** (bibliothèque @matrix-org/olm, Apache-2.0), éprouvée en production et disponible en WebAssembly dans le navigateur. **Olm** (Double Ratchet) établit les sessions 1-à-1 qui transportent, chiffrées et **signées ed25519**, les clés de salon ; **Megolm** chiffre les salons (1-pour-N) avec ratchet par message. À chaque changement de membre (arrivée, départ, révocation), l'« epoch » du salon s'incrémente et force une **nouvelle session Megolm** : un agent parti ne reçoit plus jamais de clé, un nouvel arrivant ne lit pas l'historique antérieur. **Aucune cryptographie développée par l'équipe** n'est utilisée.

4. Composants open source et licences.

Composant	Licence	Usage
Node.js 24 / Express 5 / ws	MIT	serveur API et WebSocket
SQLite (module node:sqlite)	domaine public	base de données, zéro dépendance native
@matrix-org/olm	Apache-2.0	chiffrement Olm/Megolm (protocole Matrix)
otpauth (RFC 6238)	MIT	second facteur TOTP
qrcode	MIT	enrôlement TOTP par QR
esbuild	MIT	agrégation du client
WebCrypto (W3C)	standard	AES-GCM fichiers, PBKDF2 scellement

Aucune API ni service tiers n'est requis. Code du projet sous **AGPL-3.0** (LICENSE à la racine du dépôt).

5. Niveau d'engagement open source : Étendre et adapter. Nous étendons et adaptons la pile cryptographique du protocole Matrix : nous bâtissons sur la bibliothèque olm et adaptons ses mécanismes — distribution de clés de salon par sessions Olm signées ed25519, rotation Megolm pilotée par l'epoch de salon, consommation unique des clés jetables — au contexte de l'administration burkinabè (enrôlement nominatif, rôles, canaux institutionnels, révocation d'État). Chaque technologie est citée avec sa licence ; chaque fonction de sécurité est couverte par les tests automatisés (« npm test », 10 tests e2e rejouant les épreuves en direct) et expliquée ligne à ligne dans docs/EXPLICATION_CODE.md.

6. Fonctionnalités innovantes (contexte burkinabè).

→ **Classification des messages** — Diffusion restreinte / Confidentiel : expiration automatique (30 min à 7 jours, suppression côté serveur), filigrane nominatif du lecteur, copie bloquée, aucune fonction de transfert par conception, avertissement à l'envoi en Confidentiel ;

→ **Annuaire officiel** des agents par ministère et fonction, recherche, démarrage de conversation en un clic, et **canaux institutionnels** (instructions de service) à écriture réservée aux encadrants ;

→ **Interface en français et en mooré** (salutations et déconnexion ; couverture partielle, à étendre avec des locuteurs natifs) ;

→ **Socle** : révocation immédiate multi-appareils avec effacement local à distance, empreinte ed25519 vérifiable hors canal, journal d'audit des enrôlements, connexions et révocations.

7. Répartition des rôles dans l’équipe.

Membre	Périmètre
[Membre 1 — chef de projet]	architecture serveur, API, Docker, intégration continue
[Membre 2]	chiffrement client (Olm/Megolm, fichiers), tests e2e de sécurité
[Membre 3]	interface (UX, classification, annuaire, mooré), documentation et vidéo

Chaque membre participe aux revues de code des deux autres périmètres : l’entretien technique peut désigner n’importe lequel d’entre nous.